

CI/CD con enfoque DevSecOps

Caso Forseti — Facturación electrónica SRI Ecuador

Hernán Jurado · Ingeniería en Software

UDLA · Facultad de Ingeniería y Ciencias Aplicadas

ISWZ3205 · Procesos de Software · Julio 2026

github.com/TARIUS-S-A-S/forseti-devsecops

1 · El problema

Forseti es un SaaS de facturación electrónica **en producción** que emite comprobantes al SRI Ecuador firmados con XAdES-BES.

Tres riesgos combinados

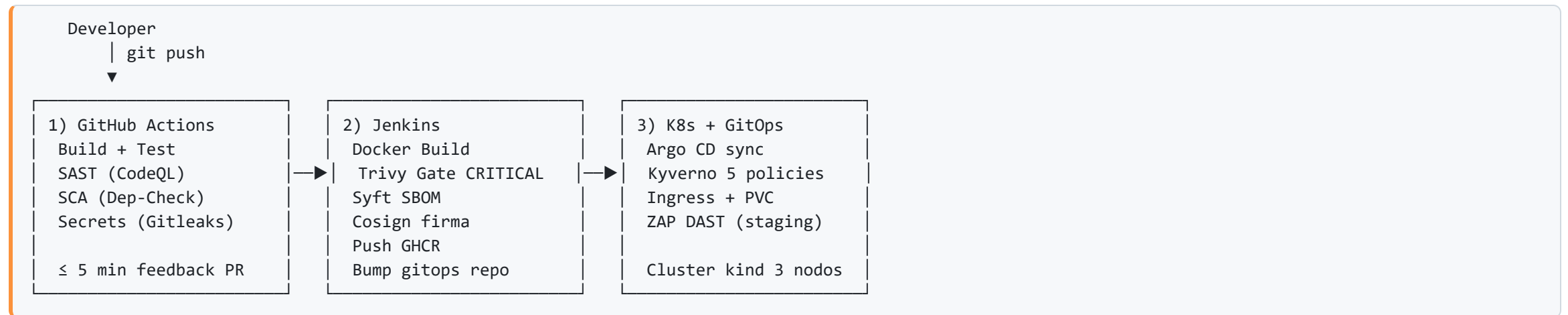
-  **Compliance LOPDP** — procesa RUCs, direcciones, correos: datos personales bajo la Ley Orgánica de Protección de Datos.
-  **Certificados digitales** — maneja `.p12` privados cifrados con AES-256-GCM. Un fallo de firma corrompe la validez fiscal.
-  **Cadencia alta** — la base tributaria SRI cambia 2 veces al año. No podemos frenar releases.

Pregunta guía

¿Cómo entregamos rápido sin aflojar la seguridad?

Respuesta → pipeline con **DevSecOps** integrado en cada etapa — no al final.

2 · Arquitectura en 3 capas



Regla de oro: cada herramienta hace lo que hace mejor. Nada se pisa.

3 · Matriz de herramientas — sin redundancia

#	Etapas	Herramienta	Rol único (que las demás NO cubren)
1	CI orquestador	GitHub Actions	Feedback en el PR mismo (≤ 5 min)
2	SAST	CodeQL	Bugs en código Java + TS sin ejecutar
3	SCA (deps)	OWASP Dep-Check	CVEs en Maven <code>pom.xml</code> + npm <code>package-lock</code>
4	Secrets	Gitleaks	Credenciales en historial Git
5	CD orquestador	Jenkins	Release engineering con gates
6	SCA (imagen)	Trivy	CVEs en OS + libs de la imagen final
7	SBOM	Syft	Inventario SPDX de cada imagen
8	Signing	Cosign (Sigstore)	Firma keyless + key-based
9	GitOps CD	Argo CD	Sync declarativo del cluster
10	Policy	Kyverno	Admission control YAML-nativo
11	DAST	OWASP ZAP	Vulns en runtime del deploy

11 herramientas, 11 responsabilidades distintas. Descartadas: GitLab CI, Snyk, Notary v2, OPA/Gatekeeper, FluxCD, Prometheus. Justificado en el informe.

4 · CI en GitHub Actions — evidencia real

5 workflows en paralelo por PR — feedback ≤ 5 min · SAST CodeQL · SCA Dep-Check · Secrets Gitleaks · CI Build+Test · CD por rama.

Estrategia de ramas: `feature/*` → solo CI en PR · `dev` → CI + staging · `main` → CI + CD completo.
Branch protection en `main` obliga 5 status checks verdes.

The screenshot shows a GitHub pull request for the repository `TARIUS-S-A-S / forseti-devsecops`. The pull request is titled `docs: sección de estrategia de ramas en README #1` and is open. The pull request shows 6 commits, 8 checks, and 6 files changed. The status bar indicates `+1323 -31` changes. The pull request is triggered by a push to the `dev` branch from the `feature/demo-devsecops` branch.

The pull request details section shows the following workflows:

- SCA — OWASP Dependency-Check (on: pull_request)
- OWASP Dep-Check (Java + JS) (on: pull_request) — This workflow is currently running and is highlighted in blue.
- SAST — CodeQL (on: pull_request)
- CI (all branches + PR) — Build + Test (on: pull_request)
- Secrets Scan — Gitleaks (on: pull_request)

The OWASP Dep-Check (Java + JS) workflow is shown in detail, indicating it started 29m 12s ago. The workflow is a SCA (Software Composition Analysis) tool used for dependency checking.

9 stages: Checkout · Build imágenes Docker (paralelo BE/FE) · Trivy Scan · Trivy Gate
CRITICAL  · Syft SBOM · Push GHCR · Cosign firma + attest · ZAP DAST · Bump GitOps.

Jenkins

forseti-devsecops-pipeline

Status

Changes

Construir ahora

Borrar Pipeline

Configure

Rename

Full Stage View

Favorite

Open Blue Ocean

Pipeline Syntax

Git Log de consultas

forseti-devsecops-pipeline

Pipeline principal: build → Trivy → Syft → Cosign → ZAP → GitOps commit

editar descripción

Stage View

Average stage times:

	Declarative: Checkout SCM	Checkout	Build imágenes Docker	Backend	Frontend	Trivy — Scan CVEs (imagen)	Backend	Frontend	Trivy — Gate CRITICAL	Syft — SBOM SPDX	Push a GHCR
	1s	1s	147ms	27s	16s	240ms	0ms	0ms	820ms	150ms	134ms

	Declarative: Checkout SCM	Checkout	Build imágenes Docker	Backend	Frontend	Trivy — Scan CVEs (imagen)	Backend	Frontend	Trivy — Gate CRITICAL	Syft — SBOM SPDX	Push a GHCR
#8 jul 10 20:31 1 commit	1s	1s	158ms	6s	5s	357ms	2s	3s	892ms failed	156ms failed	136ms failed
#7 jul 10 20:16 7 commits	1s	1s	213ms	6s	4s	267ms	1s	1s	1s failed	189ms failed	159ms failed
#6 jul 10 19:41 1 commit	2s	1s	155ms	4s	3s	189ms	1s	1s	903ms failed	131ms failed	135ms failed
#5 jul 10 19:31 1 commit	1s	1s	160ms	4s	3s	229ms	1s	2s	927ms failed	148ms failed	128ms failed

Scan real contra `forseti-backend:local` con Trivy 0.72.0 · 7 CRITICAL + 8 HIGH en libs Spring/Thymeleaf.

CVEs destacados: `CVE-2026-40477` Thymeleaf SSTI · `CVE-2026-22732` Spring Security bypass · `CVE-2026-40973` Spring Boot RCE.

forseti-backend:local (alpine 3.23.5) - Trivy Report - 2026-07-11 01:10:04.11013028 +0000 UTC m=+0.327714962					
alpine					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	
libexpat	CVE-2026-56131	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/pull/1267 https://nvd.nist.gov/vuln/detail/CVE-2026-56131
libexpat	CVE-2026-56407	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/pull/1262 https://nvd.nist.gov/vuln/detail/CVE-2026-56407
libexpat	CVE-2026-56408	HIGH	2.8.1-r0	2.8.2-r0	https://github.com/libexpat/libexpat/commit/1262 https://nvd.nist.gov/vuln/detail/CVE-2026-56408
p11-kit	CVE-2026-2100	HIGH	0.25.5-r2	0.26.2-r0	https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 Toggle more links
p11-kit-trust	CVE-2026-2100	HIGH	0.25.5-r2	0.26.2-r0	https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 https://access.redhat.com/errata/RHSA-2026-0210 Toggle more links
No Misconfigurations found					
jar					
Package	Vulnerability ID	Severity	Installed Version	Fixed Version	

7 · GitOps con Argo CD — el cluster refleja Git

Regla: el cluster NO acepta cambios directos — todo viene del repo `forseti-devsecops-gitops` (source of truth). Argo CD **multi-source** combina chart Helm + values.yaml.

Beneficios: auditoría automática (`git log` = historia deploys) · rollback = `git revert` · cero `kubectl apply` manuales. App `forseti-staging` = Synced + Healthy ✅.

The screenshot shows the Argo CD web interface for the application 'forseti-staging'. The interface is divided into a sidebar on the left and a main content area. The sidebar contains navigation links: Applications, Settings, User Info, and Documentation. The main content area displays the application's health status as 'Healthy' and its sync status as 'Synced'. Below this, there is a detailed view of the application's resources, including 'forseti-staging' (ns), 'forseti-postgres-pvc' (pvc), 'forseti-secrets' (secret), 'forseti-backend' (svc), 'forseti-frontend' (svc), 'forseti-postgres' (svc), 'forseti-backend-56f9847c9b' (rs), and 'forseti-backend-56f9847c9b' (pod). The application is shown as Synced and Healthy, with a last sync time of 2 hours ago.

8 · Kyverno — última línea de defensa

5 políticas enforce activas en el cluster

Policy	Rechaza si...
verify-forseti-image-signatures	Imagen sin firma Cosign válida
require-resource-limits	Container sin requests o limits
disallow-latest-tag	Tag :latest en forseti-prod
disallow-privileged-containers	privileged=true , hostNetwork/PID/IPC
require-run-as-non-root	runAsNonRoot no está en true

Prueba en vivo — Kyverno bloqueando 3 políticas al mismo tiempo

```
$ kubectl -n forseti-prod run test-latest --image=nginx:latest --dry-run=server

Error from server: admission webhook "validate.kyverno.svc-fail" denied the request:
  disallow-latest-tag/block-latest: 'En forseti-prod está prohibido el tag :latest'
  require-resource-limits/validate-limits: 'container debe declarar requests + limits'
  require-run-as-non-root/check-runasnonroot: 'runAsNonRoot debe ser true'
```

9 · Resultados, aprendizajes, mejoras y cierre

Herramienta	Tipo	Resultado real capturado
CodeQL	SAST	0 alertas críticas · Java + TS
OWASP Dep-Check	SCA deps	3 MEDIUM transitivas · 0 HIGH/CRIT
Trivy	SCA imagen	7 CRITICAL + 8 HIGH en Spring/Thymeleaf
Gitleaks	Secrets	0 hallazgos · 2.44 MB escaneados
OWASP ZAP	DAST	59 PASS · 7 WARN · 0 FAIL
Cosign	Firma	100% imágenes firmadas Sigstore
Kyverno	Policy	3 pods rechazados en vivo

 **Métricas:** Commit → staging ≈22 min · PR ≤5 min · 7 herramientas seguridad · 0 CVEs CRIT sin mitigar

 **Validado:** Separar CI (GH Actions) de CD pesado (Jenkins) · Multi-source Argo CD con GitOps aparte · **Cosign** + **Kyverno** convierten la firma en real · kind + Docker Desktop reproducible en 15 min.

 **Mejoras:** Renovate/Dependabot · Falco runtime · Sealed-Secrets/ESO · Argo Rollouts (canary) · Bump Spring 6.4.6 + Thymeleaf 3.1.4.